



EWU CYBERSECURITY CLUB

//

SESSION AT IIT, DHAKA UNIVERSITY



Email Forensics

Tracing Digital Evidence in the Inbox

Presented by **Zaber Mahmud**

EWU Cybersecurity Club



```
$ grep -i "Received:"  
evidence.eml  
$ dig txt company.com | grep spf  
$ sha256sum attachment.pdf
```

WHO AM I??

ZABER MAHMUD



- ❖ Vice President [Technical], EWUCSC
- Security Researcher | Blue Teamer | Penetration Tester
- Certified Network Security Practitioner (CNSP)
- Certified Appsec Practitioner (CAP)
- APIsec Certified Practitioner (ACP)
- Certified API Security Analyst (CASA)

You are Connected with : [Facebook](#) | [Linkedin](#) | [Twitter](#)



What We'll Cover Today

01

What Is Email?

Architecture, protocols, and how a message actually travels

02

Why Email Forensics?

The purpose and value of forensic email analysis

03

Why It Matters at Work

Incident response in the corporate / job sector

04

Core .eml Concepts

Headers, authentication, and the artifacts that matter

05

Live Demonstration

Walking through a real suspicious email

06

Linux Commands

The command-line toolkit for email evidence



What Is Email?

Electronic mail is a **store-and-forward** messaging system. A message is composed, handed to a server, relayed across the internet through one or more intermediate servers, and finally stored in the recipient's mailbox — every hop leaves a trace.

SMTP

Simple Mail Transfer Protocol — sends / relays mail (port 25 / 587)

POP3

Post Office Protocol — downloads mail, usually removing it from server

IMAP

Internet Message Access Protocol — syncs mail while it stays on server

MESSAGE JOURNEY

Sender (MUA)



Sender's Mail Server (MTA)



Recipient's Mail Server (MTA)



Recipient (MUA)



Why Do We Need Email Forensics?

Email forensics is the systematic examination of email content, headers and metadata to establish authenticity, origin, and intent as digital evidence.

1

#1 Attack Vector

Phishing, malware and social engineering overwhelmingly begin with a single crafted email.

2

Spoofing & Fraud

Headers can be forged — forensics tells a real sender from an impersonated one.

3

Legal Evidence

Properly preserved emails hold up in court and internal disciplinary proceedings.

4

Timeline Reconstruction

The Received chain rebuilds exactly who sent what, to whom, and when.

5

Scope of a Breach

Tracing one malicious email reveals how far an attacker's access may have spread.

6

Accountability

Message-ID and server logs tie an action back to a specific account or device.



Why It's Needed After a Workplace Incident



Business Email Compromise (BEC)

Fraudulent wire-transfer requests impersonating a CEO or vendor — one of the costliest corporate email crimes.



Insider Data Exfiltration

An employee emailing confidential files to a personal or competitor address before resignation.



HR & Legal Disputes

Harassment complaints, policy violations, or wrongful-termination cases that hinge on message authenticity.



Regulatory Compliance

Breach-notification laws (e.g. GDPR) require organizations to prove what happened and when.



Incident Response Root Cause

Determining the exact phishing email that gave an attacker their initial foothold.



Main Concepts for .eml Analysis

Header Fields

From, To, Return-Path, Reply-To, Message-ID — the sender's claimed and real identity.

Received Chain

Read bottom-to-top: each hop's server, timestamp and IP — the true path a message took.

Authentication (SPF / DKIM / DMARC)

Cryptographic and policy checks that reveal whether a message was actually sent by its claimed domain.

Originating IP

X-Originating-IP / first Received header — traced via WHOIS to a real-world location or host.

Timestamps & Time Zones

Gaps or inconsistent offsets in the Received chain can expose a forged or relayed header.

Attachments & Links

Hashing attachments and inspecting embedded URLs for malware or credential-phishing pages.



Anatomy of an Email Header



```
Received: from mail.spoofted-domain.ru (203.0.113.44)

Received: from smtp.corp-mail.com (198.51.100.9)

From: "HR Department" <hr@company.com>

Return-Path: <billing@sp00fted-corp.ru>

Reply-To: payouts@sp00fted-corp.ru

Message-ID: <a1b2c3@mail.spoofted-domain.ru>

Subject: Urgent: Update Payroll Details

Authentication-Results: spf=fail dkim=fail dmarc=fail
```

READ IT BOTTOM-TO-TOP



Mismatch

From domain vs. Return-Path / Reply-To domain don't match.



Auth failure

SPF, DKIM or DMARC shows fail instead of pass.



Unexpected hop

A Received server that has no reason to be in the chain.



Look-alike domain

"sp00fted-corp" vs. the real "spoofed-corp" — one character off.



Live Demonstration: Analyzing a Suspicious Email

01

Acquire

Export the message as .eml, preserving the original file untouched for evidentiary integrity.

02

Inspect Headers

Open the raw source and read the Received chain, From / Return-Path, and Message-ID.

03

Verify Authentication

Check the Authentication-Results header for SPF, DKIM and DMARC pass/fail.

04

Trace the IP

Take the earliest Received IP and run a WHOIS / geolocation lookup on it.

05

Examine Attachments & Links

Hash any attachment and inspect embedded URLs before ever opening them.

06

Document Findings

Record every artifact and hash value to build a defensible forensic report.



Linux Commands for Email Forensics

```
$ grep -i "Received:" file.eml
```

List every hop in the Received chain

```
$ cat file.eml | head -40
```

Quickly view raw headers at the top of the file

```
$ exiftool file.eml
```

Pull metadata from the message and any attachments

```
$ ripmime -i file.eml -d out/
```

Extract MIME attachments into a directory

```
$ munpack -t file.eml
```

Alternative tool to unpack MIME attachments

```
$ sha256sum out/attachment.pdf
```

Hash an attachment for integrity & malware lookup

```
$ dig txt company.com | grep spf
```

Check a domain's published SPF record

```
$ whois 203.0.113.44
```

Identify the owner / origin of a suspicious IP

```
$ strings file.eml | less
```

Search for readable text in binary attachments



Key Takeaways

- 1 Email forensics reconstructs the truth behind a message — who really sent it, from where, and when.
- 2 Never trust the From field alone: cross-check Return-Path, Reply-To, and the Received chain.
- 3 SPF, DKIM and DMARC are the fastest signal of a forged sender.
- 4 In the job sector, this skill directly protects against BEC fraud, insider leaks, and HR disputes.
- 5 A handful of Linux commands — grep, exiftool, ripmime, whois — cover most first-pass analysis.



Thank You

Questions & Discussion

Zaber Mahmud

EWU Cybersecurity Club

Session at IIT, Dhaka University

```
$ whoami
zaber.mahmud
$ echo "stay curious"
```